PLAN-05 - Backend, Permissions, and Security

POS-DGFY - Global Location Switching | Plan v1.0 | Revision 2026-09-27

Field	Value
Project	POS-DGFY - Global Location Switching
Plan version	1.0
Section	PLAN-05 - Backend, Permissions, and Security
Revision date	2026-09-27
Plan status	NOT EXECUTION READY
Purpose	Define trusted enforcement, API reuse, authorization, transaction safety, and security verification.
Dependencies	PLAN-03 and PLAN-04; existing POS routes, controllers, use cases, repositories, and permission contract.

Backend strategy

Reuse the existing switch-location endpoint and use case. Extend only the missing module scope checks discovered during Phase 354. Keep controllers transport-only and enforce rules in use cases and repositories according to the repository architecture boundary.

Authentication, authorization, and data scope

Layer	Question	Required check
Authentication	Who is the caller?	Authenticated tenant user, active account, valid session/operator.
Authorization	What may the caller do?	pos:switch_location plus module-specific action permission.
Data scope	Which records may the caller access?	Location grant, terminal assignment, shift ownership, and requested viewing scope.

API behavior

- Reuse POST /pos/terminal/shifts/:id/switch-location.
- Validate shift ID, terminal pairing, destination location, destination terminal, closing cash, opening float, reason, notes, and idempotency key.
- Derive tenant, actor, cashier, source location, and current shift from trusted session and database state.
- Reject client attempts to override protected identity or scope fields.
- Return deterministic errors: 403 for authorization, 409 for conflict/state race, 422 for invalid input, and 5xx only for unexpected failures.

Atomicity and idempotency

- Lock the source shift and destination terminal/shift records as required by the existing data model.
- Perform close/open transition and audit write in one transaction.
- Reuse idempotency keys so retries do not create duplicate transitions or cash events.
- Preserve the source state if any destination validation or write fails.

Security checks

ID	Attack or failure	Verification
SEC-001	Forged location_id or terminal_id.	Direct API request with altered identifiers must fail.
SEC-002	Permission without location grant.	User with pos:switch_location but no destination grant receives 403.
SEC-003	Viewing context used for mutation.	Mutation request using viewing scope is rejected.
SEC-004	Cross-tenant identifier substitution.	Tenant ownership query rejects foreign IDs.
SEC-005	Replay or duplicate submit.	Same idempotency key returns the original outcome.
SEC-006	Sensitive audit/log leakage.	Logs contain IDs and reasons, not passwords, tokens, or payment secrets.

Backend exit criteria

- All protected APIs use trusted scope checks.
- Concurrency tests prove no double-open or cross-location shift state.
- Audit and reconciliation records are produced for success and failure.
- No new API duplicates the existing governed switch flow.